Université de Perpignan
C. Negre

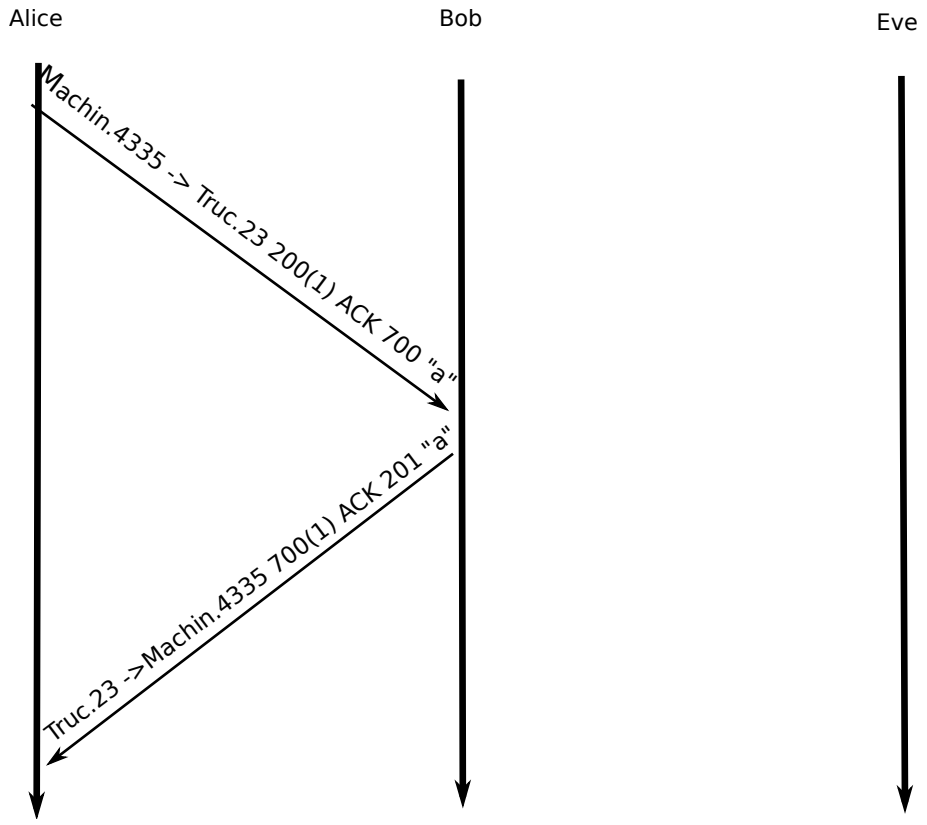
L3 Info
Année 2025

TD4 Sécurité

Sécurité des réseaux

Exercice 1 (Vol de session TCP)**.** Un attaquant Eve espionne une connexion `telnet` entre Alice et Bob. Notez que dans l'application telnet lors d'un envoi d'un Alice→Bob d'un message M, celui-ci est renvoyé en echo Bob→Alice pour acquittement.

Eve forge un paquet TCP pour insérer la commande `\n echo HACKED \n` dans le flux de données. Le dernier échange de paquets avant s'insertion est illlustré ci-dessous. Complétez la figure ci-dessous avec le paquet inséré et les paquets qui suivront entre Alice et Bob.



Exercice 2 (Trafic réseau suspect)**.** Conrad Ministrateur, un informaticien qui travaille pour une banque suisse est responsable du bon fonctionnement et de la sécurité du réseau de son employeur. Un matin, lors d'un contrôle de routine, il remarque du trafic suspect à destination du serveur qui gère la base de données des comptes bancaires des clients.

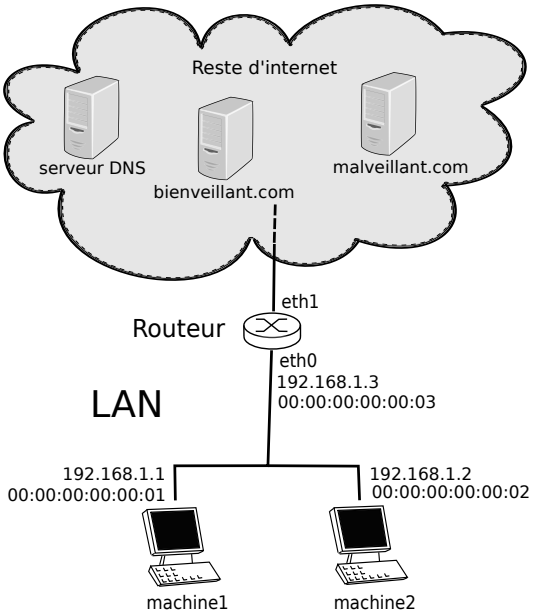
Voici un extrait de ce trafic:

```
02:01:27 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:27 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:27 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
```

```
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:28 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
02:01:29 arp reply 192.168.94.1 is-at 0:3:47:48:5c:ee
```

Sachant que l'adresse `192.168.94.1` est celle de la passerelle qui offre un accès à Internet à ce serveur, interpréter ce trafic de manière concise.

Exercice 3. On considère deux machines machine1 et machin2 dans un réseaux local connecté à internet par un routeur. On considère aussi un serveur web `bienveillant.com` auquel veut accéder l'utilisateur de machine1 et `malveillant.com`. Les adresses IP et adresses MAC sont données ci-dessous:



1. On suppose que la machine `machine1` fait un ping vers l'adresse IP 192.168.1.2: il émet le paquet suivant sur le réseau

   ```
   192.168.1.1 envoie [ARB who-as? 192.168.1.2] à FF:FF:FF:FF:FF:FF
   ```

   Expliquez comment l'attaquant sur machine2 doit faire pour que les données transmises par machine1 au routeur lui soit d'abord transmise.

2. Expliquez ensuite comment l'attaque sur machine2 doit s'y prendre pour que machine1 envoie ses requetes web à `site-malveillant.com` au lieu de `mon-gentil-site.com`.

Exercice 4. Jean-Michel Pyrhatt a remarqué qu'une requête de transfert de zone DNS (utilisé notamment pour fournir à un serveur DNS esclave l'information concernant la ou les zones qu'il doit dessert) fait toujours 27 octets de long et que la réponse du serveur DNS `dns.machinchose.ch` fait 745 octets. On admettra que les communications se font au moyen d'UDP.

1. Comment Jean-Michel Pyrhatt peut-il réaliser une attaque par déni de service contr le serveur `pauvre.victime.com` ?

2. Si Jean-Michel Pyrhatt possède une bande passante de 1Mbps et qu'il est capable de l'utiliser à 100% pour son attaque, quelle sera la bande passante appartenant à `pauvre.victime.com` qui sera utilisée par l'attaque ?

Exercice 5 (Attaque de Kevin Mitnick)**.** Le trafic décrit ci-dessous a été observé dans un réseau (cas réel). De quoi s'agit-il ? Les paquets TCP sont décrits à l'aide de lignes ayant le format suivant :

```
14.18.37.26 alice.513 > bob.514: P 1382727010.1382727011(2) ack 2024384001
```

On a :

- l'heure `14.18.37.26`
- l'adresse source (`alice`)
- le port source (`513`)
- l'adresse de detination (`bob`)
- le port de destination (`514`)
- un drapeau éventuel (`S`=SYN, `P`=PUSH, `F`=FIN, `R`=RESET, `.` = pas de drapeau.
- Les numéro de séquence du premier octet et du dernier octet du datagramme (1382727010.1382727011).
- le nombre d'octets transmis `2`.
- Un éventuel acquittement des octets reçus (`ACK`).
- Le numéro de séquence du prochain octet attendu (`2024384001`).

```
14:18:22.516699 mallory.600 > alice.513: S 1382726960:1382726960(0) win 4096
14:18:22.566069 mallory.601 > alice.513: S 1382726961:1382726961(0) win 4096
14:18:22.744477 mallory.602 > alice.513: S 1382726962:1382726962(0) win 4096
14:18:22.830111 mallory.603 > alice.513: S 1382726963:1382726963(0) win 4096
14:18:22.886128 mallory.604 > alice.513: S 1382726964:1382726964(0) win 4096
14:18:22.943514 mallory.605 > alice.513: S 1382726965:1382726965(0) win 4096
14:18:23.002715 mallory.606 > alice.513: S 1382726966:1382726966(0) win 4096
14:18:23.103275 mallory.607 > alice.513: S 1382726967:1382726967(0) win 4096
14:18:23.162781 mallory.608 > alice.513: S 1382726968:1382726968(0) win 4096
14:18:23.225384 mallory.609 > alice.513: S 1382726969:1382726969(0) win 4096
14:18:23.282625 mallory.610 > alice.513: S 1382726970:1382726970(0) win 4096
14:18:23.342657 mallory.611 > alice.513: S 1382726971:1382726971(0) win 4096
14:18:23.403083 mallory.612 > alice.513: S 1382726972:1382726972(0) win 4096
14:18:23.903700 mallory.613 > alice.513: S 1382726973:1382726973(0) win 4096
14:18:24.003252 mallory.614 > alice.513: S 1382726974:1382726974(0) win 4096
14:18:24.084827 mallory.615 > alice.513: S 1382726975:1382726975(0) win 4096
14:18:24.142774 mallory.616 > alice.513: S 1382726976:1382726976(0) win 4096
14:18:24.203195 mallory.617 > alice.513: S 1382726977:1382726977(0) win 4096
14:18:24.294773 mallory.618 > alice.513: S 1382726978:1382726978(0) win 4096
14:18:24.382841 mallory.619 > alice.513: S 1382726979:1382726979(0) win 4096
14:18:24.443309 mallory.620 > alice.513: S 1382726980:1382726980(0) win 4096
14:18:24.643249 mallory.621 > alice.513: S 1382726981:1382726981(0) win 4096
14:18:24.906546 mallory.622 > alice.513: S 1382726982:1382726982(0) win 4096
14:18:24.963768 mallory.623 > alice.513: S 1382726983:1382726983(0) win 4096
14:18:25.022853 mallory.624 > alice.513: S 1382726984:1382726984(0) win 4096
14:18:25.153536 mallory.625 > alice.513: S 1382726985:1382726985(0) win 4096
14:18:25.400869 mallory.626 > alice.513: S 1382726986:1382726986(0) win 4096
14:18:25.483127 mallory.627 > alice.513: S 1382726987:1382726987(0) win 4096
14:18:25.599582 mallory.628 > alice.513: S 1382726988:1382726988(0) win 4096
```

```
14:18:25.653131 mallory.629 > alice.513: S 1382726989:1382726989(0) win 4096
......
4:18:25.906002 kevin.1000 > bob.514: S 1382726990:1382726990(0) win 4096
14:18:26.094731 bob.514 > kevin.1000: S 2021824000:2021824000(0) ack 1382726991 win 4096
14:18:26.172394 kevin.1000 > bob.514: R 1382726991:1382726991(0) win 0
14:18:26.507560 kevin.999 > bob.514: S 1382726991:1382726991(0) win 4096
14:18:26.694691 bob.514 > kevin.999: S 2021952000:2021952000(0) ack 1382726992 win 4096
14:18:26.775037 kevin.999 > bob.514: R 1382726992:1382726992(0) win 0
14:18:26.775395 kevin.999 > bob.514: R 1382726992:1382726992(0) win 0
14:18:27.014050 kevin.998 > bob.514: S 1382726992:1382726992(0) win 4096
14:18:27.174846 bob.514 > kevin.998: S 2022080000:2022080000(0) ack 1382726993 win 4096
14:18:27.251840 kevin.998 > bob.514: R 1382726993:1382726993(0) win 0
14:18:27.544069 kevin.997 > bob.514: S 1382726993:1382726993(0) win 4096
14:18:27.714932 bob.514 > kevin.997: S 2022208000:2022208000(0) ack 1382726994 win 4096
14:18:27.794456 kevin.997 > bob.514: R 1382726994:1382726994(0) win 0
14:18:28.054114 kevin.996 > bob.514: S 1382726994:1382726994(0) win 4096
14:18:28.224935 bob.514 > kevin.996: S 2022336000:2022336000(0) ack 1382726995 win 4096
14:18:28.305578 kevin.996 > bob.514: R 1382726995:1382726995(0) win 0
14:18:28.564333 kevin.995 > bob.514: S 1382726995:1382726995(0) win 4096
14:18:28.734953 bob.514 > kevin.995: S 2022464000:2022464000(0) ack 1382726996 win 4096
14:18:28.811591 kevin.995 > bob.514: R 1382726996:1382726996(0) win 0
14:18:29.074990 kevin.994 > bob.514: S 1382726996:1382726996(0) win 4096
14:18:29.274572 bob.514 > kevin.994: S 2022592000:2022592000(0) ack 1382726997 win 4096
14:18:29.354139 kevin.994 > bob.514: R 1382726997:1382726997(0) win 0
14:18:29.354616 kevin.994 > bob.514: R 1382726997:1382726997(0) win 0
14:18:29.584705 kevin.993 > bob.514: S 1382726997:1382726997(0) win 4096
14:18:29.755054 bob.514 > kevin.993: S 2022720000:2022720000(0) ack 1382726998 win 4096
14:18:29.840372 kevin.993 > bob.514: R 1382726998:1382726998(0) win 0
14:18:30.094299 kevin.992 > bob.514: S 1382726998:1382726998(0) win 4096
14:18:30.265684 bob.514 > kevin.992: S 2022848000:2022848000(0) ack 1382726999 win 4096
14:18:30.342506 kevin.992 > bob.514: R 1382726999:1382726999(0) win 0
14:18:30.604547 kevin.991 > bob.514: S 1382726999:1382726999(0) win 4096
14:18:30.775232 bob.514 > kevin.991: S 2022976000:2022976000(0) ack 1382727000 win 4096
14:18:30.852084 kevin.991 > bob.514: R 1382727000:1382727000(0) win 0
14:18:31.115036 kevin.990 > bob.514: S 1382727000:1382727000(0) win 4096
14:18:31.284694 bob.514 > kevin.990: S 2023104000:2023104000(0) ack 1382727001 win 4096
14:18:31.361684 kevin.990 > bob.514: R 1382727001:1382727001(0) win 0
14:18:31.627817 kevin.989 > bob.514: S 1382727001:1382727001(0) win 4096
14:18:31.795260 bob.514 > kevin.989: S 2023232000:2023232000(0) ack 1382727002 win 4096
14:18:31.873056 kevin.989 > bob.514: R 1382727002:1382727002(0) win 0
14:18:32.164597 kevin.988 > bob.514: S 1382727002:1382727002(0) win 4096
14:18:32.335373 bob.514 > kevin.988: S 2023360000:2023360000(0) ack 1382727003 win 4096
14:18:32.413041 kevin.988 > bob.514: R 1382727003:1382727003(0) win 0
14:18:32.674779 kevin.987 > bob.514: S 1382727003:1382727003(0) win 4096
14:18:32.845373 bob.514 > kevin.987: S 2023488000:2023488000(0) ack 1382727004 win 4096
14:18:32.922158 kevin.987 > bob.514: R 1382727004:1382727004(0) win 0
14:18:33.184839 kevin.986 > bob.514: S 1382727004:1382727004(0) win 4096
14:18:33.355505 bob.514 > kevin.986: S 2023616000:2023616000(0) ack 1382727005 win 4096
14:18:33.435221 kevin.986 > bob.514: R 1382727005:1382727005(0) win 0
14:18:33.695170 kevin.985 > bob.514: S 1382727005:1382727005(0) win 4096
14:18:33.985966 bob.514 > kevin.985: S 2023744000:2023744000(0) ack 1382727006 win 4096
14:18:34.062407 kevin.985 > bob.514: R 1382727006:1382727006(0) win 0
14:18:34.204953 kevin.984 > bob.514: S 1382727006:1382727006(0) win 4096
14:18:34.375641 bob.514 > kevin.984: S 2023872000:2023872000(0) ack 1382727007 win 4096
14:18:34.452830 kevin.984 > bob.514: R 1382727007:1382727007(0) win 0
14:18:34.714996 kevin.983 > bob.514: S 1382727007:1382727007(0) win 4096
```

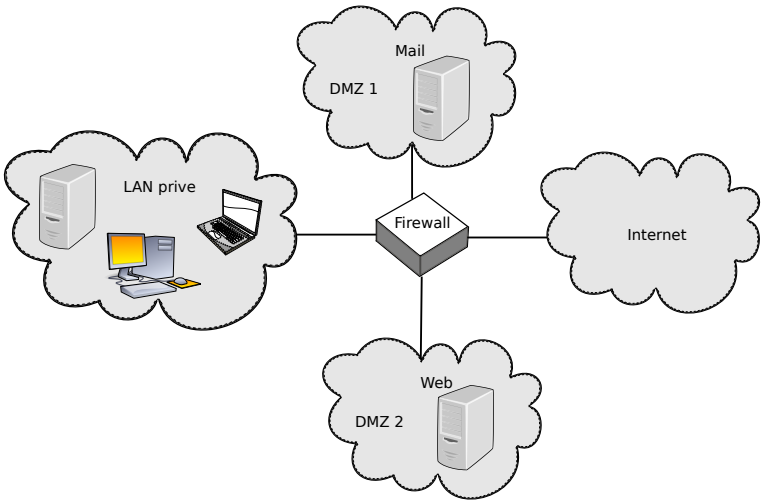
```
14:18:34.885071 bob.514 > kevin.983: S 2024000000:2024000000(0) ack 1382727008 win 4096
14:18:34.962030 kevin.983 > bob.514: R 1382727008:1382727008(0) win 0
14:18:35.225869 kevin.982 > bob.514: S 1382727008:1382727008(0) win 4096
14:18:35.395723 bob.514 > kevin.982: S 2024128000:2024128000(0) ack 1382727009 win 4096
14:18:35.472150 kevin.982 > bob.514: R 1382727009:1382727009(0) win 0
14:18:35.735077 kevin.981 > bob.514: S 1382727009:1382727009(0) win 4096
14:18:35.905684 bob.514 > kevin.981: S 2024256000:2024256000(0) ack 1382727010 win 4096
14:18:35.983078 kevin.981 > bob.514: R 1382727010:1382727010(0) win 0
....
14:18:36.245045 alice.513 > bob.514: S 1382727010:1382727010(0) win 4096
14:18:36.755522 alice.513 > bob.514: .                          ack 2024384001 win 4096
14:18:37.265404 alice.513 > bob.514: P 1382727010:1382727011(2) ack 2024384001 win 4096
14:18:37.775872 alice.513 > bob.514: P 1382727012:1382727016(5) ack 2024384001 win 4096
14:18:38.287404 alice.513 > bob.514: P 1382727017:1382727041(25) ack 2024384001 win 4096
14:18:36.755522 alice.513 > bob.514: .                          ack 2024384002 win 4096
14:18:36.755522 alice.513 > bob.514: .                          ack 2024384003 win 4096
14:18:43.165874 alice.513 > bob.514: F 1382727041:1382727041(0) ack 2024384003 win 4096
14:18:52.179922 alice.513 > bob.514: R 1382727043:1382727043(0) win 4096
14:18:52.236452 alice.513 > bob.514: R 1382727044:1382727044(0) win 4096
.....
14:18:52.298431 mallory.600 > alice.513: R 1382726960:1382726960(0) win 4096
14:18:52.363877 mallory.601 > alice.513: R 1382726961:1382726961(0) win 4096
14:18:52.416916 mallory.602 > alice.513: R 1382726962:1382726962(0) win 4096
14:18:52.476873 mallory.603 > alice.513: R 1382726963:1382726963(0) win 4096
14:18:52.536573 mallory.604 > alice.513: R 1382726964:1382726964(0) win 4096
14:18:52.600899 mallory.605 > alice.513: R 1382726965:1382726965(0) win 4096
14:18:52.660231 mallory.606 > alice.513: R 1382726966:1382726966(0) win 4096
14:18:52.717495 mallory.607 > alice.513: R 1382726967:1382726967(0) win 4096
14:18:52.776502 mallory.608 > alice.513: R 1382726968:1382726968(0) win 4096
14:18:52.836536 mallory.609 > alice.513: R 1382726969:1382726969(0) win 4096
14:18:52.937317 mallory.610 > alice.513: R 1382726970:1382726970(0) win 4096
14:18:52.996777 mallory.611 > alice.513: R 1382726971:1382726971(0) win 4096
14:18:53.056758 mallory.612 > alice.513: R 1382726972:1382726972(0) win 4096
14:18:53.116850 mallory.613 > alice.513: R 1382726973:1382726973(0) win 4096
14:18:53.177515 mallory.614 > alice.513: R 1382726974:1382726974(0) win 4096
14:18:53.238496 mallory.615 > alice.513: R 1382726975:1382726975(0) win 4096
14:18:53.297163 mallory.616 > alice.513: R 1382726976:1382726976(0) win 4096
14:18:53.365988 mallory.617 > alice.513: R 1382726977:1382726977(0) win 4096
14:18:53.437287 mallory.618 > alice.513: R 1382726978:1382726978(0) win 4096
14:18:53.496789 mallory.619 > alice.513: R 1382726979:1382726979(0) win 4096
14:18:53.556753 mallory.620 > alice.513: R 1382726980:1382726980(0) win 4096
14:18:53.616954 mallory.621 > alice.513: R 1382726981:1382726981(0) win 4096
14:18:53.676828 mallory.622 > alice.513: R 1382726982:1382726982(0) win 4096
14:18:53.736734 mallory.623 > alice.513: R 1382726983:1382726983(0) win 4096
14:18:53.796732 mallory.624 > alice.513: R 1382726984:1382726984(0) win 4096
14:18:53.867543 mallory.625 > alice.513: R 1382726985:1382726985(0) win 4096
14:18:53.917466 mallory.626 > alice.513: R 1382726986:1382726986(0) win 4096
14:18:53.976769 mallory.627 > alice.513: R 1382726987:1382726987(0) win 4096
14:18:54.039039 mallory.628 > alice.513: R 1382726988:1382726988(0) win 4096
14:18:54.097093 mallory.629 > alice.513: R 1382726989:1382726989(0) win 4096
```

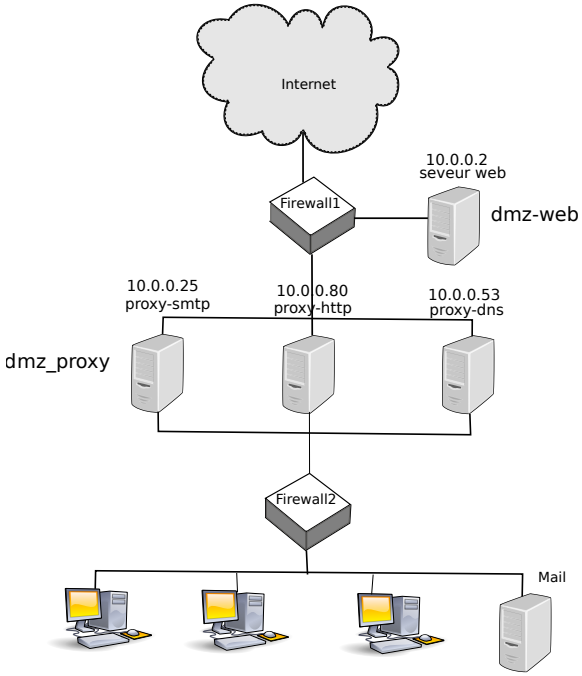
Exercice 6. On considère un pare-feu sans état qui abrite la machine 203.167.75.1. L'utilisateur de cette machine souhaite naviguer sur le Web, recevoir des connexions `telnet` provenant de l'extérieur du réseau interne, ainsi que recevoir et initier des connexions SSH de et vers internet. Les servurs HTTP, `telnet` et SSH utilisent repsectivement les ports 80,23,22.

Écrire la table de filtrage du pare-feu en utilisant le critère de filtrage sur les paquets SYN (flag SYN

à 1 et flag ACK à 0).

Exercice 7. On considère la règle de parefeu avec état pour le réseau donné ci-dessous. La règle A du pare-feu permet aux machines du LAN privé d'accéder à la DMZ 2, alors que la règle C devait l'interdire. Comment remédier à cela?



Règle	@ src	@ dest.	Protocole	Port source	Port dest.	Action
A	Toutes	DMZ 2	TCP	Tous	80	Autorisé
B	LAN	DMZ 1	TCP	Tous	25	Autorisé
C	LAN	Toutes	TCP	Tous	Tous	Refusé
E	Tous	Tous	Tous	Tous	Tous	Refusé

Exercice 8. On considère l'architecture réseau donnée ci-dessous. Les Firewall sont des pare-feu avec état. Le serveur web a pour adresse IP 10.0.0.2 et les proxy SMTP, HTTP, DNS les adresses IP respectires 10.0.0.25, 10.0.0.80, 10.0.0.53. Le serveur web doit être accessible par le réseau interne. On désignera dmz-proxy les adresses IP de tous les proxy. Donnez les règles du Firewall1 qui permette d'assurer ces fonctionnalités.